

PROJECT PROPOSAL:

WEBSITE BLACKBOX PENETRATION TESTING

Client: RSM

Submitted On: 29th - Nov

Submitted By: KITE

WWW.KITE.COM.SA



“Perfection is qchieved, not where there is nothing more to qdd, when there is nothing keft to tqke qwqy,”

-KITE

Next page

Company Profile 2024

COMPANY

TABLE OF CONTENTS

ABOUT US 04

INTRODUCTION 05

SCOPE OF WORK 06

PRE-REQUISITES 08

KITE’S METHODOLOGY 09

TOOLS 10

CONFIDENTIALITY 11

CHANGES AND REVISIONS 12

TERMS AND CONDITIONS 12

YOUR INVESTMENT 13

PAYMENT TERMS 13

ABOUT THE COMPANY



CONFIDENTIAL

Knowledge Partners Information Technology EST (KITE) strives to understand the changing customer needs in line with increasing demands of industry. KITE works constantly upgrading the quality, customize the technology, study, develop, enhance, implement maintain and support various IT services overseas. We serve with equal ease with dedicated, committed domain experts. Our aim is to exceed client expectations by developing solutions we can be proud of.

Our professional consulting and technical teams provide our clients with a broad range of innovative solutions and services to improve the performance and efficiency, while optimizing technology investments. Our good will comes from treating every customer with professional respect and integrity.

Shajeeulla Khan
Business Development Manager

PROJECT INTRODUCTION



Security vulnerabilities have been exploited through the threats that has triggered. This normally occurs when threats are exploited and they materialize just as if it is an incident. In order to make it easy to counter such threats they require a cost risk analysis. It can be in form of networks, operating system or hardware and even in form of applications. Recommendations are also necessary given according to the threats and vulnerability assessed.

We use top-of-the-line scanning software from Open-source applications to run periodic vulnerability scans & Penetration Tastings on your systems. While we recommend weekly or monthly scans to reduce exposure time between scans, the frequency of scans varies based on your particular risk environment and the service plan you opt for. After the scanning process, our team classifies the vulnerabilities detected into CRITICAL, HIGH, MEDIUM, LOW severity categories and creates a vulnerability tracking page to help you draw up a remediation plan. Remediation measures may include applying appropriate patches, making configuration changes, restricting network access where needed, and accepting the risk where remediation is not feasible.

We conduct periodic meetings with your IT and business teams to go over your risk profile and important threat vectors, and the measures you can take to mitigate risk. Our security team also helps you prepare a risk acceptance document for vulnerabilities that cannot be remediated and require compensating controls until complete remediation such as application or system upgrade becomes possible. These may also include vulnerabilities that are not relevant to your specific business needs.

Next page Company Profile 2024

OUR EXPERTS GO BEYOND JUST THAN SCAN & PEN TEST

SCOPE OF WORK

Internal & External Vulnerability Assessment and Penetration Testing

The scope of work outlined in this proposal encompasses a comprehensive Vulnerability Assessment and Penetration Testing (VAPT) service tailored to the specific requirements of the client. The objective is to identify and address potential security vulnerabilities across a range of critical servers, maintaining the integrity and confidentiality of your organization's information assets.

Target Servers

The VAPT services will be conducted on the following servers within the client's infrastructure:

Item	Description
Domain Controller	Internal VAPT x 2
Exchange Server	Internal & External VAPT x 3
Symantec Antivirus	Internal VAPT x 1
Data Classification Application Server	Internal VAPT x 1
Symantec Data Encryption	Internal VAPT x 1
File server	Internal VAPT x 1
Web server	Internal & External VAPT x 1

Assessment Frequency

The VAPT services will be conducted on a monthly basis over the course of one year. This equates to a total of 12 assessments, allowing for a consistent and proactive approach to identifying and mitigating vulnerabilities as they emerge.

Methodology

The assessment methodology will involve a combination of automated scanning tools and manual testing techniques to ensure a comprehensive evaluation. This includes internal and external assessments, as well as specific testing for the web application, both internally and externally.

Automated Scanning

Utilization of industry-leading automated scanning tools to perform initial scans for common vulnerabilities, misconfigurations, and potential security loopholes.

Manual Testing

Hands-on manual testing by skilled security professionals to supplement automated scans. This includes a deeper analysis of identified vulnerabilities, focusing on potential exploits and complex security issues.

Internal Assessment

Evaluation of the security of the network from within, simulating an attack by a trusted insider. This phase will identify and address internal threats, such as unauthorized access and privilege escalation.

External Assessment

Evaluation of the network and systems from an external perspective, simulating an attack by an external threat actor. This phase focuses on identifying vulnerabilities exploitable by external attackers.



Web Application Testing

For the web application, a combination of White Box testing (internally) and Black Box testing (externally) will be conducted. This includes a detailed examination of the internal code and logic, as well as simulating external attacks

Compliance Checks

Assessment of systems against industry standards and compliance requirements relevant to client's, ensuring adherence to necessary security regulations.

Reporting

Detailed reports will be generated for each assessment, providing a summary of findings, severity levels of vulnerabilities, and recommended remediation steps. Reports will be user-friendly yet comprehensive, facilitating informed decision-making

Continuous Improvement

The scope includes a commitment to continuous improvement, adapting the assessment approach based on emerging threats, technological advancements, and changes in the client's infrastructure.

Next page
Company Profile 2024

PRE -REQUISITES

01 Authorization for Internal Vulnerability Assessment: Prior to the commencement of the Internal Vulnerability Assessment (VAPT) on the network, it is essential for the client to provide explicit permission.

02 Installation of Proprietary Scripts: In order to facilitate the assessment process, proprietary scripts will be installed on the devices earmarked for evaluation. Appropriate permissions should be granted to enable this installation.

03 Network Access and Validation: Access to the networks will be required through any suitable remote desktop software or via Public IP. This access is essential for the initial verification and validation of provided IP addresses.

04 Port Requirements for Penetration Testing: To conduct the Penetration Testing (PT) effectively, specific ports need to be opened. The client is requested to ensure that the necessary ports are accessible for the duration of the testing.

05 Public IP Access: Uninterrupted access to networks through public IP is imperative for successful connectivity during the assessment. The client is kindly requested to facilitate this access.

06 System Requirements for Local Access: To ensure a seamless assessment process, local access to one system with the following minimum specifications is required:
Processor: Intel Core i7 or equivalent
RAM: Minimum 16 GB or higher
Disk Space: Minimum 150 GB free space or more
Network Card: 1 Gbps
Operating System: Ubuntu 20.04.3 LTS or a later version

Your cooperation in granting these permissions and ensuring the stipulated conditions will greatly contribute to the effectiveness and thoroughness of the Vulnerability Assessment and Penetration Testing.
If you have any concerns or require further clarification on these requirements, please do not hesitate to contact us.

KITE'S METHODOLOGY

Our Vulenrability Assessement and Penetration Testing methodology follows a systematic approach to identify and exploit vulnerabilities as an external attacker would. The process includes:



1 **Reconnaissance:**
Gather information about the target websites, such as domain names, IP addresses, and publicly available data.

2 **Scanning:**
Identify live hosts, open ports, and services running on the target servers.
Conduct vulnerability scanning to discover known vulnerabilities.

3 **Enumeration:**
Gather additional details about the target environment to aid in the penetration testing process.

4 **Vulnerability Analysis:**
Analyze identified vulnerabilities and prioritize them based on severity and potential impact.

5 **Exploitation:**
Attempt to exploit vulnerabilities to gain unauthorized access.

6 **Post-Exploitation:**
Establish and maintain access.
Perform further reconnaissance to escalate privileges and move laterally within the network.

7 **Documentation and Reporting:**
Document all steps taken, vulnerabilities identified, and successful exploits.
Provide a comprehensive report with findings, recommendations, and risk mitigation strategies.



Next page
Company Profile 2024

TOOLS



A combination of in-dustry-standard and custom tools will be used for the Black Box Penetration Testing, including but not limited to:

- ✓ Nessus for vulnerability scanning.
- ✓ Invicti for vulnerability scanning.
- ✓ Nmap for network scanning.
- ✓ Metasploit for exploitation and post-exploitation.
- ✓ Burp Suite for web application testing.
- ✓ Wireshark for network analysis.

CONFIDENTIALITY

All findings and sensitive information discovered during the testing will be treated with the utmost confidentiality and will only be shared with authorized personnel.

DATA PROTECTION:

All data and information obtained during the Black Box Penetration Testing, including but not limited to system configurations, network layouts, and identified vulnerabilities, will be handled with the utmost care.

LIMITED ACCESS:

Access to the testing results, raw data, and any documentation generated will be restricted to a limited and defined set of authorized personnel directly involved in the testing process. This typically includes the penetration testing team members and relevant managerial or administrative staff.

NON-DISCLOSURE AGREEMENT (NDA):

A formal Non-Disclosure Agreement (NDA) can be established between the testing team and the client, reinforcing the commitment to keeping all information confidential. The NDA may outline legal consequences for any unauthorized disclosure of sensitive information.

SECURE COMMUNICATION:

During the testing process, all communication related to findings, progress, and any other sensitive matters will be conducted through secure channels. This may include encrypted email communication, secure file transfer methods, and other secure collaboration tools.

DATA ENCRYPTION:

Any data collected and stored during the testing, including the testing reports, will be encrypted to add an extra layer of protection. This ensures that even if unauthorized access were to occur, the data would remain secure and unreadable without the appropriate decryption keys.

SECURE STORAGE:

Any physical or digital storage used to store testing-related data, reports, or documentation will be secure and access-controlled. This prevents unauthorized individuals from gaining access to the information.

SECURE DISPOSAL:

Once the testing engagement is complete and the client has received the final report, any additional copies of data or documents will be securely disposed of to prevent any inadvertent disclosure.

CLIENT CONTROL OVER INFORMATION:

The client retains control over the distribution and dissemination of the testing results. No information will be shared externally without the explicit consent and authorization of the client.

Next page Company Profile 2024

CHANGES AND REVISIONS

We know from experience that fixed-price contracts are rarely beneficial to you, as they often limit you to your earliest ideas. We don't want to limit your ability to change your mind or make decisions later when you might be better informed. The price at the beginning of this contract is based on the length of time & Server Specifications we estimate, we'll need to accomplish everything you've told us you want to achieve, but we're happy to be flexible. If you want to change your mind or add anything new, that won't be a problem as we'll provide a separate estimate for to cover the additional work.

TERMS AND CONDITIONS

In case of rejection or cancellation of the project, the client shall not unreasonably withhold acceptance of, or payment for, the project. If, prior to completion of the project.

If the client observes any nonconformance with the design plan, KITE must be promptly notified, allowing for necessary corrections. Rejection of the completed project or cancellation during its execution will result in forfeit of deposit and the possible billing for all additional labor or expenses to date.

Functionality or feature requests above and beyond those listed in the budget and/or the functionality specs may be considered out-of-scope and an amendment to the budget will be recommended.

We agree to use our best efforts to fulfill and exceed your expectation on the deliverables listed above. You agree to aid us in doing so by making available to us needed information pertaining to your website and to cooperate with us in expediting the work.

If the project encounters any delay more than three months from the client in receiving contents or getting appropriate approvals or feedback due to any unjustified reason or occurrence then we will be eligible to submit a new change request for the additional charges that would require our time & effort.

You have the right to modify, reject, cancel or stop any and all plans or work in process. However, you agree to reimburse us for all costs and expenses we incurred prior to your change in instructions, and which relate to non-cancelable commitments, and to defend, indemnify and hold us harmless for any liability relating to such action. We agree to use our best efforts to minimize such costs and expenses.

We agree to treat as confidential any information related to the Assignment

To keep the information confidential and not disclose to any third party any confidential information, know-how or trade secrets to which we have access to by reason of the "Assignment"

Agree to carry the Project in relation to the assignment in professional manner

Agree not to share any information acquired by us in the course of our work with others who do not have a need to have the information



Next page

YOUR INVESTMENT

S No	Item	Quantity	Price (SAR)	Total (SAR)
Website - Blackbox Penetration				
1	Monthly VAPT on the devices mentioned in the	12		
			Discount	**1,000**
			VAT 15 %	
			Total Inclusive of VAT	

PAYMENT TERMS

S No	Item	Description
1	50%	Advance
2	50%	After Project Completion

For KITE	For RSM
Shajeeulla Khan 	
Title: Business Development Manager	Title:

Next page

Company Profile 2024

KITE

MOBILE
+96655 930 3303

EMAIL
INFO@KITE.COM.SA

WEB
WWW.KITE.COM.SA